hochschule burgenland
University of Applied Sciences

IT-Governance als Einflussfaktor der Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten

Bachelorarbeit

Department Informationstechnologie

Von
– Name –
Andrea Ungerer

Betreuer: Dipl.-Ing. Wolfram Rinke

Department Informationstechnologie –Department–:
–Studiengang–
Datum: 30. März 2026

Inhaltsverzeichnis

1 Kurzfassung 2

2 Einleitung 2
2.1 Problemstellung 2
2.2 Zielsetzung und wissenschaftliche Fragestellung 3

3 Grundlagen 4
3.1 Allgemeine Definitionen 4
3.2 Historische Entwicklung – von 1FA zu MFA 5
3.3 Relevante Protokolle und Technologien 6
3.3.1 Authentifizierung & Autorisierung 6
3.3.2 Endgeräte 7
3.4 MFA und Regulatorik 8
3.5 Verwendungskontext und Akzeptanz 9
3.6 Usability und Mensch-Maschine-Interaktion 9

4 Stand des Wissens 10
4.1 Einflussfaktoren 10
4.1.1 Technische Einflussfaktoren 10
4.1.2 Einflussfaktoren mit Bezug auf Nutzer:innen 11
4.1.3 Einflussfaktoren mit Bezug zur IT-Governance 12
4.2 Wirkmechanismen der Nutzung von MFA 13

5 Forschungsmethodik 14
5.1 Forschungsdesign und wissenschaftstheoretische Einordnung 14
5.1.1 Systematische Literaturrecherche als theoretisches Fundament 15
5.1.2 Operationalisierung und theoriegeleitete Itemgenerierung 15
5.2 Grundgesamtheit und Stichprobenziehung 15
5.3 Methodisches Vorgehen und Instrumentenentwicklung 16
5.3.1 Operationalisierung und Itemgenerierung 16
5.3.2 Aufbau des Online-Fragebogens 17
5.3.3 Pre-Test und Datenerhebung 17
5.4 Datenaufbereitung und Auswertungsverfahren 17

6 Zusammenfassung 18

7 Zusammenfassung 18

8 Anhang 20

1 Kurzfassung

Digitale Authentifizierungstechnologien befinden sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability, welches in der vorliegenden Seminararbeit vorgestellt und diskutiert werden soll. Diese Vielschichtigkeit stellt Unternehmen und Personen vor die Herausforderung, wie sie sensible Daten und Zugriffe darauf nachhaltig sichern können. Ein-Faktor-Authentifizierung kann dieses Problem nicht (mehr) lösen, da dieser Faktor häufig ein singuläres Passwort ist, dessen Anfälligkeit für Manipulation umfangreich dokumentiert wurde (Joseph Bonneau et al., 2015, S. 81-82). Gleichzeitig verzeichnen mehrere europäische Organisationen einen starken Anstieg von identitätsbezogenen Angriffen gegen Einzelpersonen und Unternehmen (European Union Agency for Cybersecurity., 2024, S. 27). Multi-Faktor-Authentifizierung schließt diese Lücke, indem wie im Namen ersichtlich, unterschiedliche zusätzliche Faktoren Teil der Identitätsfeststellung werden (Lawrence O'Gorman und O'Gorman, 2003, S. 2022-2024). Weiters nehmen die Bedrohungen im Internet zu. Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen Privatpersonen und Unternehmen gleichermaßen. Ein-Faktor-Authentifizierungssysteme stellen in diesem Zusammenhang ein großes Risiko dar, weil sie leicht umgangen werden können, und vor allem in Form von Passworten anfällig sind für menschliche Faktoren, wie Bequemlichkeit oder Vergesslichkeit (Das et al., 2020, S. 5446). Insbesondere sensible Bereiche wie das Gesundheitswesen, Banken sowie die öffentlichen Verwaltung müssten mit großen Folgen einer Kompromittierung der Daten rechnen, weshalb Guidelines und Standards dringend notwendig sind (EBA publishes an Opinion on the elements of strong customer authentication under PSD2 | European Banking Authority, o. J., S. 12). Dieser wissenschaftliche Text soll untersuchen, welche Faktoren auf die Verwendung von MFA-Technologien einwirken. Dabei liegt der Fokus nur teilweise auf den Bereich Usability und Akzeptanz der Technologie, sondern vorwiegend auf dem Bereich Governance als Einflussfaktor. Dieser wird vor allem in Hinblick auf die wachsende Menge an IT-Regularien und Governance-Anforderungen in unterschiedlichen Kontexten zunehmend auch für Privatpersonen beziehungsweise in privaten Kontexten relevant.

2 Einleitung

2.1 Problemstellung

Digitale Authentifizierungstechnologien bewegen sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability. Diese Dualität stellt Unternehmen wie Privatpersonen vor die Herausforderung, sensible Daten und Zugriffe nachhaltig zu sichern. Die klassische Ein-Faktor-Authentifizierung (1FA) kann dieses Problem nicht mehr lösen, da der Faktor „Wissen“ (meist ein Passwort) durch menschliche Schwächen wie Vergesslichkeit oder Bequemlichkeit anfällig ist und dessen Manipulierbarkeit in der Literatur umfangreich dokumentiert wurde (Bonneau et al., 2015, S. 81). Gleichzeitig verzeichnen europäische Organisationen einen massiven Anstieg von identitätsbezogenen Angriffen (European Union Agency for Cy-

bersecurity, 2024, S. 27). Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen dabei private und korporative Akteure gleichermaßen. In diesem Kontext stellt die alleinige Nutzung von Passwörtern ein inakzeptables Risiko dar (Das et al., 2020, S. 5446). Multifaktor-Authentifizierung (MFA) schließt diese Sicherheitslücke, indem sie zusätzliche, voneinander unabhängige Faktoren in die Identitätsfeststellung integriert (O'Gorman, 2003, S. 2023). Insbesondere in sensiblen Sektoren wie dem Gesundheitswesen, dem Bankensektor oder der öffentlichen Verwaltung hätte eine Kompromittierung verheerende Folgen, weshalb verbindliche Standards und Guidelines hier dringend erforderlich sind (EBA, o. J., S. 12). Die vorliegende Arbeit untersucht, welche Faktoren die effektive Nutzung von MFA beeinflussen. Während Aspekte der Usability und Akzeptanz als Rahmenbedingungen betrachtet werden, liegt der primäre Fokus auf IT-Governance als steuerndem Element. Obwohl Governance üblicherweise im Unternehmenskontext verortet wird, gewinnt sie durch die wachsende Anzahl an IT-Regularien (NIS-2, DORA, FIDA, CRA) zunehmend auch für Privatpersonen an Relevanz, da berufliche Sicherheitsvorgaben und private Nutzungsgewohnheiten zunehmend verschwimmen.

2.2 Zielsetzung und wissenschaftliche Fragestellung

Multifaktor-Authentifizierung (MFA) stellt weit mehr dar als eine rein technische Standardlösung für das Identitäts- und Zugangsmanagement. Sie bewegt sich in einem komplexen Anforderungsfeld: Die Technologie muss nicht nur kryptografisch sicher und resistent gegen Manipulation sein, sondern gleichzeitig externe Compliance-Anforderungen erfüllen und durch Benutzerfreundlichkeit Risiken minimieren, die durch menschliches Fehlverhalten entstehen (Kim et al., 2011, S. 187). In diesem Kontext nimmt IT-Governance eine Schlüsselrolle ein. Durch Richtlinien und strategische Vorgaben können Unternehmen Sicherheitsaspekte mit den Interessen der Stakeholder in Einklang bringen (Wibowo & Ramli, 2022, S. 2). Auf Basis der ermittelten Authenticator Assurance Levels (AAL) werden Technologien und Prozesse definiert, um diese Ziele zu erreichen. Damit verortet sich das Thema nachvollziehbar im Bereich des strategischen IT-Infrastruktur-Managements.

Daraus abgeleitet lautet die zentrale Forschungsfrage der vorliegenden Arbeit:

> *Welchen Einfluss hat die IT-Governancen auf die Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten?*

Als Unterfragen ergeben sich:

- sub 1a. Welche Motivationen zur Umstellung auf MFA gibt es?
- sub 1b. (Grundsätzlich - was kann sein?) Welche Vorgaben kann die IT-Governance auf die Verwendung von MFA im beruflichen Kontext definieren?
- sub 2. (Konkret Umsetzung - Literatur) Wie konkretisieren sich die technischen und organisatorischen Vorgaben bezogen auf MFA im beruflichen Kontext?
- sub 3. Welche Konsequenzen hat die Umsetzung der IT-Governance-Vorgaben bei der Verwendung der MFA auf die Belegschaft?

- sub 4. (Wie weit in Realität und Literatur auseinander?) Wie wirkt sich die Verwendung der MFA im beruflichen Umfeld auf die private Nutzung aus?

Methodisch stützt sich die vorliegende Arbeit auf ein zweistufiges Forschungsdesign. Den theoretischen Unterbau bildet eine Literaturrecherche, bei der relevante wissenschaftliche Publikationen, Fachartikel und Standards (z. B. NIST, ISO) analysiert werden, um sowohl die technischen Aspekte von MFA als auch die organisatorischen Governance-Faktoren zu beleuchten. Darauf aufbauend erfolgt zur Überprüfung der aufgestellten Hypothesen eine quantitative Datenerhebung in Form einer standardisierten Online-Umfrage. Dieses Vorgehen ermöglicht es, die Nutzungsmuster im beruflichen und privaten Kontext empirisch gegenüberzustellen, den Spill-over-Effekt statistisch zu quantifizieren und weiters Erfolgsfaktoren zu identifizieren. Dafür wurden berufstätige Personen im DACH-Raum, die regelmäßig mit IT-Systemen und digitalen Authentifizierungsverfahren konfrontiert sind, als Zielgruppe definiert. Die gewonnenen Erkenntnisse tragen dazu bei, die Schnittstelle zwischen beruflicher IT-Governance und privater Sicherheitskultur besser zu verstehen und daraus praxisrelevante Handlungsempfehlungen abzuleiten. Die Relevanz dieser Arbeit ergibt sich insbesondere für (angehende) IT-Manager:innen sowie Verantwortliche im Bereich Identity- und Access-Management (IAM), um Entscheidungen mit stärkerem Nutzer:innen-Fokus zu treffen und Organisationen auf die steigenden Anforderungen von regulatorischen Vorgaben vorzubereiten.

3 Grundlagen

3.1 Allgemeine Definitionen

Authentifizierung bezeichnet den technischen Prozess, bei dem ein System die behauptete, digitale Identität einer Person prüft. Dabei ist sie von Identitätsfeststellung (Identity Proofing) und Autorisierung zu unterscheiden (Temoshok et al., 2025a–c).

Klassisch erfolgte Authentifizierung mittels eines Faktors, über Wissen (zum Beispiel Passwort). Angesichts bekannter Schwächen von Passwörtern und darauf abgestimmter Angriffsformen empfiehlt der NIST-Rahmen abhängig vom Risiko der Anwendung höhere Authenticator Assurance Levels (AAL) bis hin zu verpflichtender Multifaktor-Authentifizierung (MFA) (Temoshok, 2025; Temoshok et al., 2025b). MFA kombiniert mindestens zwei unabhängige Faktorarten (O'Gorman & O'Gorman, 2003, S. 2022):

- **Besitz** („Something you have“): Smartcard, Hardware-Schlüssel, Token.
- **Inhärenz** („Something you are“): biometrische Merkmale (zum Beispiel Fingerabdruck, Gesichtsscan).
- **Wissen** („Something you know“): Passwort, PIN, Sicherheitsfragen.

Neue Darstellungen erweitern diese drei klassischen Faktoren um zwei weitere:

- **Ortsbezug** („Somewhere you are“): IP-Adresse, Geolocation.

- **Tätigkeitsbezug** („Something you do“): Verhalten mit dem Gerät, Klick- und Tippverhalten (OWASP, o. J.).

Für den vorliegenden Text liegt der Fokus jedoch auf den drei obengenannten Faktoren. Einerseits aufgrund ihrer dichteren Forschungslage, andererseits um Kreuzbeziehungen (zum Beispiel: Wie wirkt Unternehmensgovernance auf den Arbeitsort und die IP-Adresse bei Home-Office-Regelungen?) zu reduzieren, die hier nicht in der gebührenden Komplexität dargestellt werden könnten. Zur Absicherung digitaler Identitäten wird eine Kombination mehrerer etablierter Protokolle und Technologien verwendet, um sowohl die Identitätsprüfung als auch die Zugriffssteuerung zu regeln (Rose et al., 2020, S. 6). Auf diese wird in Folge genauer eingegangen. Während traditionelle Modelle oft auf örtlichen (sogenannten perimeterbasierten) Ansätzen beruhten, erfordern moderne Architekturen eine kleinteilige Unterscheidung zwischen der Verifizierung einer Identität (Authentifizierung) und der Gewährung von Zugriffsrechten (Autorisierung) (Shirey, 2007, S. 25–28). Entscheidend ist die Unabhängigkeit der Faktoren voneinander, aber auch ihre Bindung an die Nutzer:in und das verwendete Protokoll (zum Beispiel bei einem kryptografischen Herausforderungs-Antwort-Verfahren). Damit steigt die Resistenz gegen Phishing oder technische Manipulation, wie etwa bei FIDO2/WebAuthn als besitzbasierten, kryptografischen Faktoren (Lang et al., 2016, S. 423). In risikobasierten Ansätzen (RBA) werden zusätzliche Faktoren bei auffälligem Kontext angefordert (Wiefling et al., 2019). Allerdings sind sie im Hinblick auf die Anfälligkeit von Passwörtern durchaus auch unter anderen Umständen zu empfehlen (Otta et al., 2023, S. 4).

3.2 Historische Entwicklung – von 1FA zu MFA

„In times gone by, authentication was not a complex task. One person, call her Alice, would meet another person, Bob, and either recognize him by visual appearance or not. [. . .] Now we cannot ‘see’ the entity on the remote end of a computer network, and indeed the entity could be a friend, a machine, or an attacker. We exchange personal information, such as financial and health data, that we wish to remain as private and as confidential as correspondence between spies.“ (O’Gorman, 2003, S. 2001)

Die Entwicklung der digitalen Authentifizierung ist eng mit der allgemeinen Informationssicherheit verbunden. Schon in den 1960er-Jahren wurden Passwörter als primäre Methode zur Zugangskontrolle eingeführt und über Jahrzehnte als Standard eingesetzt (Bonneau et al., 2015, S. 78–80). Dieses Prinzip geht von der Annahme aus, dass nur autorisierte Personen das zugrunde liegende „Geheimnis“ kennen (O’Gorman & O’Gorman, 2003, S. 2022). Mit der zunehmenden Vernetzung und Komplexität moderner IT-Systeme steigen allerdings die Sicherheitsrisiken sukzessiv. Das beeinflusst nur teilweise die Sensibilisierung von Nutzer:innen bezüglich IT-Risiken: Empirische Studien zeigen, dass Nutzer:innen häufig dieselben oder sehr einfache Passwörter für mehrere Dienste wiederverwenden, um die kognitive Belastung zu reduzieren (Florêncio et al., 2007, S. 660). Dieser menschliche Faktor führt zu einer hohen Anfälligkeit für Angriffe wie Credential Stuffing (Kunke et al., 2021, S. 59) und erleichtert Brute-Force-Angriffe (Bonneau et al., 2012, S. 555). Als Re-

aktion auf diese Schwachstelle entstanden Zwei-Faktor-Authentifizierungsverfahren (2FA), die erstmals Besitzfaktoren wie Hardware-Token oder mobile TAN-Generatoren einbezogen. Der Übergang zur Mehrfaktor-Authentifizierung (MFA) erfolgte in Schritten, indem biometrische und kontextbezogene Merkmale ergänzt wurden (Temoshok et al., 2025, S. 14). Aktuelle Authentifizierungssysteme vereinen technische Innovationen mit Anforderungen an Datenschutz, Benutzerfreundlichkeit und regulatorische Vorgaben, etwa im Finanzwesen durch die Zahlungsdienst-Richtlinie PSD2 (de Bruijn & Janssen, 2017, S. 3). Damit bildet MFA heute einen zentralen Bestandteil moderner Sicherheitsarchitekturen, der technologische sowie auch organisatorische Aspekte vereint. Gängige Multi-Faktor-Authentifizierungssysteme nutzen eine Vielzahl technischer Verfahren, die sich (unter anderem) im Sicherheitsniveau, hinsichtlich ihrer Benutzerfreundlichkeit und im Implementierungsaufwand unterscheiden (Mohammed et al., 2023, S. 4). Die Verbindung mehrerer Faktoren erhöht die Resilienz gegenüber unbefugten Zugriffen, da Angreifer:innen nicht mehr nur ein einzelnes Geheimnis kompromittieren müssen. Dabei ist die erwähnte Unabhängigkeit der Faktoren und Bindung der Faktoren an Gerät und Nutzer:in entscheidend, wie sie in den Digital Identity Guidelines des NIST definiert sind (Temoshok et al., 2025, S. 12–14). Zu diesem Zweck werden im Folgenden relevante Technologien und Protokolle kurz vorgestellt.

3.3 Relevante Protokolle und Technologien

3.3.1 Authentifizierung & Autorisierung

Die Authentifizierung ist der Prozess, bei dem ein Anspruchsteller/ eine Anspruchstellerin (Claimant) den Besitz und die Kontrolle über einen oder mehrere Authentifikatoren nachweist, um seine Identität gegenüber einem Bestätiger (Verifier) zu bestätigen (Temoshok et al., 2025, S. 4–5). Authentifizierungsmethoden basieren traditionell, wie einleitend erwähnt, auf drei Faktoren (NIST SP 800-63 Digital Identity Guidelines, o. J.).

Da simple Passwörter anfällig für Diebstahl und Phishing sind, gilt die MFA als Standard für höhere Sicherheitsanforderungen. MFA kombiniert mindestens zwei verschiedene dieser Faktoren, um die Sicherheit über die bloße Kenntnis eines Geheimnisses hinaus zu erhöhen; also zu Authentifizieren (Ometov et al., 2018, S. 3). Einmalpasswörter (One-Time Password, OTP) beruhen auf kurzlebigen Codes, die entweder zeit- (Time-Based One-Time Password, TOTP) oder zählerbasiert (HMAC-based One-Time Password, HOTP) generiert werden (M'Raihi et al., 2011, S. 3–4). Wird der Code per App oder Hardware-Token erzeugt, gilt das Verfahren als relativ sicher (O'Gorman, 2003). SMS-basierte Übermittlungen sind hingegen anfällig für Phishing und SIM-Swapping-Angriffe (Ulqinaku et al., 2020, S. 1200–1201). Hardware-Token und Smartcards stellen physische Besitzfaktoren dar, die über kryptografische Verfahren (beispielsweise U2F, FIDO2) eine Challenge-Response-Authentifizierung ermöglichen. Diese Lösungen gelten als besonders resistent gegen Phishing und Replay-Angriffe (Lang et al., 2016, S. 424–427), erfordern jedoch organisatorischen Aufwand bei Verwaltung und Einsatz (Pfeffer et al., 2021, S. 40–42). Biometrische Authentifizierung nutzt inhärente Merkmale wie Fingerabdruck, Gesicht oder Stimme. Sie bietet leichte Nutzung, wirft aber Fragen zum Datenschutz, zur Einwilligung und zu möglichen Spoofing-Risiken

auf (Trewin et al., 2012, S. 160–163; Wolf et al., 2019, S. 151). Ein zentraler Standard für Authentifizierung ist FIDO2, der vom W3C und der FIDO-Alliance entwickelt wurde. Er besteht aus der Web Authentication API (WebAuthn) und dem Client-to-Authenticator-Protocol (CTAP). FIDO2 ermöglicht passwortlose Authentifizierung durch asymmetrische Kryptographie, bei der private Schlüssel sicher auf einem Authentifikator (zum Beispiel YubiKey oder Smartphone-TPM) gespeichert werden und den Servern nur der öffentliche Schlüssel bekannt ist (Lyastani et al., 2020, S. 269). Zur Klassifizierung der Stärke von Authentifizierungsprozessen definiert das NIST Authentication Assurance Levels (AAL). AAL1 erfordert einfache Authentifizierung, AAL2 verlangt MFA mit zwei Faktoren, und AAL3 setzt den Einsatz kryptografischer Hardware-Token voraus, die resistent gegen Verifier-Impersonation (Phishing) sind (Temoshok et al., 2025, S. 13–14). Nach einer erfolgreichen Authentifizierung regelt die Autorisierung, auf welche Ressourcen zugegriffen werden kann, also welcher Account auf welche Art autorisiert ist. In modernen IT-Architekturen erfolgt dies oft dynamisch und kontextbezogen (Rose et al., 2020, S. 6). Häufig genutzte Modelle sind Role-Based Access Control (RBAC), bei welchem Rechte an Rollen gebunden sind, sowie Attribute-Based Access Control (ABAC), das Entscheidungen basierend auf Attributen der Nutzenden und der Umgebung trifft (Hu et al., 2014, S. 4). Im Rahmen von Zero Trust und modernen Sicherheits-Frameworks wird das Prinzip der minimalen Rechtevergabe (Least Privilege Access) durchgesetzt. Dies kann durch Just-In-Time (JIT) Zugriff erweitert werden, bei dem Privilegien nur temporär für einen spezifischen Zeitraum oder eine Aufgabe gewährt werden (Rose et al., 2020, S. 12). In zentral verwalteten Umgebungen (zum Beispiel Single Sign-On in einem Unternehmen) überträgt ein Identity Provider (IdP) Autorisierungsinformationen mittels Assertions (zum Beispiel via SAML oder OIDC) an die Relying Party (RP). Das NIST definiert hierfür Federation Assurance Levels (FAL), die festlegen, wie stark die Assertion gegen Manipulation und Injektionsangriffe geschützt ist (Temoshok et al., 2025, S. 40–44).

3.3.2 Endgeräte

Die Sicherheit des Endgeräts spielt eine entscheidende Rolle bei der Autorisierungsentscheidung, da selbst eine valide Benutzeridentität auf einem kompromittierten Gerät ein Risiko darstellt. Technologien zur Autorisierung unterscheiden zwischen Plattform Authenticators (im Endgerät integriert, zum Beispiel Apple Touch ID, Windows Hello), die oft biometrische Faktoren nutzen, und Roaming Authenticators (zum Beispiel YubiKeys), die zwischen Geräten gewechselt werden können. Die Nutzung integrierter Plattform-Authentifikatoren bindet den Zugriff stark an das spezifische Endgerät. Authenticator-Apps wie Google Authenticator oder Microsoft Authenticator implementieren typischerweise das TOTP-Verfahren (wie definiert in RFC 6238 (M'Raihi et al., 2011)). Sie sind von Mobilfunknetzen unabhängig und bieten dadurch ein höheres Sicherheitsniveau bei geringem Bedienaufwand (Temoshok et al., 2025, §4, S. 13). In einer Zero-Trust-Architektur wird keinem Gerät implizit vertraut (Rose et al., 2020, S. 11). Der Sicherheitsstatus (Device Posture), zum Beispiel Patch-Level, Malware-Freiheit oder Standort, wird kontinuierlich überwacht und fließt in Echtzeit in die Autorisierungsentscheidung ein. Um automatisierte Angriffe zu verhindern, werden Techniken wie Device Fingerprinting eingesetzt, um ein Gerät eindeutig zu identifizieren und an einen

Benutzeraccount zu binden. Dies verhindert, dass gestohlene Zugangsdaten (wie Session-Cookies) auf fremden Geräten genutzt werden können, und ermöglicht eine präzisere Risikobewertung (Tank & Dalvi, 2018, S. 29). Die Einbindung privater Endgeräte (Bring Your Own Device) stellt besondere Anforderungen an die Autorisierung, da hier die Balance zwischen Sicherheitskontrolle durch die Organisation und der Privatsphäre des Nutzers gewahrt werden muss (Miller et al., 2012, S. 54). Die Verbindung mehrerer Faktoren erhöht die Resilienz gegenüber unbefugten Zugriffen, da Angreifer:innen nicht mehr nur ein einzelnes Geheimnis kompromittieren müssen. Dabei ist die erwähnte Unabhängigkeit der Faktoren und Bindung der Faktoren an Gerät und Nutzer:in entscheidend, wie sie in den Digital Identity Guidelines des NIST definiert sind (Temoshok et al., 2025, S. 12–14). Zu diesem Zweck wurden relevante Technologien und Protokolle kurz vorgestellt. Als letztes soll auch die Kategorie Passwordless vorgestellt werden: Passwordlose Verfahren (Passwordless Login) ersetzen den Faktor „Wissen“, also ein Passwort, durch Public-Key-Kryptografie und biometrische Verifikation. Moderne Standards wie FIDO2 oder Passkeys gelten als phishing-resistent und benutzerfreundlich, werden jedoch in der Praxis eher zögerlich implementiert (Lyastani et al., 2020, S. 270).

3.4 MFA und Regulatorik

Die Implementierung von Multifaktor-Authentifizierung ist in der modernen IT-Governance nicht mehr rein risikobasiert, sondern wird zunehmend durch regulatorische Vorgaben der Europäischen Union mandatiert. Insbesondere drei Rahmenwerke sind hierbei von zentraler Bedeutung: die NIS-2-Richtlinie, DORA und die DSGVO. Die NIS- beziehungsweise NIS2-Richtlinie (Network and Information Security Directive) erweitert den Kreis der betroffenen Unternehmen („Essential“ und „Important Entities“) und verschärft die Anforderungen an die Cybersicherheit. Da sich das Inkrafttreten der NIS-2 in Österreich noch verzögert, wird hier stattdessen die Lex specialis des Digital Operational Resilience Act (DORA) herangezogen. DORA zielt auf die digitale Widerstandsfähigkeit von Finanzunternehmen ab und schreibt strenge Anforderungen an (unter anderem) das IKT-Risikomanagement vor. Bezogen auf das Identitätsmanagement verlangt DORA robuste Authentifizierungsmechanismen, um den Zugriff auf IKT-Systeme und Daten zu schützen, wobei MFA als Standardmaßnahme gilt, um die Integrität von Finanztransaktionen und Kundendaten zu gewährleisten. Auch die Datenschutz-Grundverordnung (kurz: DSGVO) wirkt als indirekter Treiber. Zwar nennt sie MFA nicht explizit, jedoch fordert Artikel 32 „geeignete technische und organisatorische Maßnahmen“, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Aufsichtsbehörden und die ENISA interpretieren MFA heute als „Stand der Technik“ für den Zugriff auf sensible personenbezogene Daten, womit eine Nicht-Verwendung bei einem Data Breach als Verstoß gegen die DSGVO gewertet werden kann.

3.5 Verwendungskontext und Akzeptanz

Die Nutzung von MFA unterscheidet sich deutlich zwischen privaten und beruflichen Kontexten. Im privaten Bereich ist MFA häufig optional und wird vor allem dort schlagend, wo regulatorische Vorgaben bestehen – zum Beispiel im Online-Banking durch PSD2 (Govindraj C.V., 2024, S. 2). Dabei stehen persönliche Faktoren wie Bequemlichkeit und Datenschutzbedenken im Vordergrund. Im beruflichen Umfeld ist IT-Governance ein treibender Faktor für die Akzeptanz von MFA. Da Sicherheit oft nicht im Fokus der Nutzer:innen ist, erzwingt Governance die Nutzung, beispielsweise durch Richtlinien und technische Kontrollen (Das et al., 2020, S. 5). In solchen Frameworks ist MFA meist verpflichtender Bestandteil eines Identity and Access Management (IAM) und dient der Einhaltung von Sicherheits- und Compliance-Standards (ISO 27001, NIST AAL2–3). Dabei erfordert ein Kompromiss zwischen Sicherheit und Benutzerfreundlichkeit sorgfältiges Vorgehen (Marky et al., 2022). Zentrale Erfolgsfaktoren für die Akzeptanz von MFA-Systemen sind daher: Onboarding (Das et al., 2018, S. 6), risikobasierte Adaption der Systeme, Datenschutz und Fallback-Möglichkeiten. Erstens intuitives Onboarding, denn eine verständliche Ersteinrichtung steigert die Akzeptanz gegenüber der Technologie (Colnago et al., 2018, S. 458–460). Zweitens minimiert die risikobasierte Authentifizierung zusätzlich Reibung, indem weitere Faktoren nur bei Bedarf, wie etwa verdächtigen Anmeldeversuchen, verlangt werden (Wiefling et al., 2019, S. 140). Drittens: Sichere Wiederherstellungsmechanismen – zum Beispiel Backup-Codes oder Hardware-Ersatz – sind notwendig, dürfen aber keine neuen Angriffsvektoren eröffnen (Klivan et al., 2023, S. 3140; Keil & Zugenmaier, 2024, S. 73). Und zuletzt: Datenschutzkonformität. Biometrische und kontextbasierte Verfahren müssen der DSGVO entsprechen (Zweckbindung, Einwilligung, Datensparsamkeit). Die Wahrnehmung von Privatsphäre beeinflusst die Akzeptanz erheblich (Malhotra et al., 2004, S. 340–341; Dienlin & Trepte, 2015, S. 285). Eine strategische Einführung der Technologie mit Schulungen, klaren Kommunikationsmaßnahmen und definierten Recovery-Prozessen ist bei Cybersecurity und Governance generell für den Erfolg entscheidend (de Bruijn et al., 2017, S. 4).

3.6 Usability und Mensch-Maschine-Interaktion

(Sasse et al., 2001, S. 1-2) Für das Verstädnis der Thematik ist auch die Mensch-Maschine-Interaktion (HCI) ein Schlüsselkonzept. Dabei handelt es sich um ein interdisziplinäres Forschungsfeld. Im Zentrum steht die Anpassung von IT-Systemen an menschliche Fähigkeiten und Grenzen. Im Kontext dieser Forschung ist die Usability von Sicherheitsmaßnahmen, insbesondere von MFA, ein zentrales Thema. Denn die Akzeptanz und korrekte Nutzung von MFA hängt maßgeblich davon ab, wie intuitiv und benutzerfreundlich die Systeme gestaltet sind (Cranor & Garfinkel, 2005, S. 1). Das führt zum Begriff der Usable Security, einer Sub-disziplin der HCI für den IT-Sicherheitskontext. (Cranor & Garfinkel, 2005, S. 1) Ziel dieser Methodiken ist, dass Sicherheitssysteme intuitiv (richtig) bedienbar sein müssen, um absichtliche oder versehentliche Umgehung zu verhindern. Das geht Hand-in-Hand mit der kognitiven Last (Cognitive Load), dem Aufwand bei der Verwendung. (Acemyan et al., 2018): Reduzieren der psychischen Anstrengung bei der Verwendung Eine Möglichkeit, um diese

Belastung zu reduzieren, ist bei der Entwicklung von IT-Systemen auf die Usability zu achten. Das bietet sich in insofern an, dass die Usability ein objektiv messbares und normiertes Kriterium ist. ISO 9241-11 (ISO, 2018) Im MFA-Kontext tritt hier die Frage nach der Aufgabe der Technologie auf (Primäraufgabe vs. Sekundäraufgabe) (Marky et al., 2022, S. 15): MFA ist nie das eigentliche Ziel der User:innen, sondern eine Sekundäraufgabe Es muss ein Kompromiss zwischen Sicherheit und Bequemlichkeit getroffen werden. Mögliche Folgen eines schlecht ausverhandelten MFA-System können „Security Fatigue“ (Sicherheitsermüdung), negative Reaktionen und die Verwendung von Workarounds sein (Fagan & Khan, 2016, S. 2).

4 Stand des Wissens

4.1 Einflussfaktoren

4.1.1 Technische Einflussfaktoren

Die technische Implementierung von Multifaktor-Authentifizierung (MFA) konfrontiert IT-Verantwortlic mit multidimensionalen Herausforderungen, die weit über die bloße Selektion eines zweiten Faktors hinausgehen. Der aktuelle Forschungsstand artikuliert ein Spannungsfeld, das von der Integration in bestehende Legacy-Architekturen über den gesamten Lifecycle der Authentifizierungstoken bis hin zur systemischen Absicherung der Recovery-Prozesse reicht. Grundlegende Publikationen definieren hierbei prinzipielle Anwendungsszenarien und Architekturen, um unterschiedliche Sicherheitsniveaus (Assurance Levels) adressieren zu können.

Ein primärer Fokus der aktuellen Forschung liegt auf der Ablösung inhärent unsicherer Verfahren. Während klassische Einmalpasswort-Verfahren (OTP) zwar weit verbreitet sind, bieten sie nur unzureichenden Schutz gegen moderne Angriffsvektoren wie Echtzeit-Phishing. In diesem Kontext werden FIDO-basierte Lösungen (insbesondere FIDO2 und WebAuthn) als vielversprechende, phishing-resistente Alternativen bewertet, die das Potenzial aufweisen, die Abhängigkeit von schwachen Passwörtern signifikant zu reduzieren.

Dennoch identifizieren systematische Untersuchungen eine deutliche Diskrepanz zwischen akademischen Sicherheitskonzepten und der tatsächlichen industriellen Praxis. Eine Analyse digitaler Zahlungssysteme verdeutlicht diese Lücke: Trotz der Verfügbarkeit fortschrittlicher Methoden basieren weiterhin ca. 33 % der untersuchten Tools primär auf klassischen OTP-Verfahren (Tran-Truong et al., 2025, S. 2–3). Diese Implementierungshürden sind besonders in stark regulierten Sektoren wie dem Finanzwesen präsent, wo technische Strategien zunehmend mit adaptiven Ansätzen und Machine Learning kombiniert werden müssen, um Sicherheitsanforderungen mit einer reibungslosen Benutzererfahrung zu harmonisieren (Aburbeian & Fernández-Veiga, 2024, S. 177–180).

Die Komplexität der MFA-Administration verschärft sich zusätzlich durch die Notwendigkeit der geräteübergreifenden Identitätsverwaltung. In Bring-Your-Own-Device (BYOD)-Szenarien muss eine sensible Balance zwischen den Sicherheitsinteressen der Organisation und dem Datenschutz der Mitarbeitenden gewahrt werden (International Journal of Computer Engineering and Management, 2024, S. 1–3).

Trotz technologischer Fortschritte verbleiben Account-Recovery-Mechanismen ein kritischer Schwachpunkt in der Sicherheitskette. Die Entwicklung robuster und zugleich nutzer:innenfreundlicher Wiederherstellungsverfahren – beispielsweise bei Verlust eines Hardware-Tokens – erweist sich als technisch anspruchsvoll, da diese Prozesse häufig neue Angriffsvektoren für Social Engineering eröffnen. Studien belegen, dass selbst hochsichere FIDO-Protokolle durch gezielte Downgrade-Angriffe untergraben werden können, wenn Websites unsichere alternative Wiederherstellungsmethoden anbieten. Angreifer können Nutzer:innen dabei manipulieren, ein FIDO-Verfahren abzubrechen und stattdessen ein schwächeres OTP-Verfahren zu nutzen, womit die ursprüngliche Phishing-Resistenz de facto eliminiert wird (Ulqinaku et al., 2021, S. 3822).

Neben der Standardisierung etablierter Verfahren untersucht die Forschung die Entwicklung gänzlich neuer Faktoren. Biometrische Verfahren werden als hochgradig komfortabel beschrieben, erweisen sich jedoch aufgrund datenschutzrechtlicher Bedenken sowie technischer Fehlerquoten wie der False Acceptance Rate (FAR) und False Rejection Rate (FRR) als herausfordernd (Ferrag et al., 2019, S. 4–8). Über konventionelle Ansätze hinaus liefern experimentelle Prototypen, beispielsweise auf Basis von Schallwellen zur Proximity-Verifikation, Impulse für zukünftige Paradigmen der Authentifizierung (Mahdad & Saxena, 2023, S. 203). Diese befinden sich jedoch größtenteils noch in einem frühen Forschungsstadium.

4.1.2 Einflussfaktoren mit Bezug auf Nutzer:innen

Zusätzlich zu den rein technischen Fragestellungen konzentriert sich ein wachsender Teil der Publikationen auf die Perspektive der Nutzenden. Aspekte wie Akzeptanz und Usability entscheiden maßgeblich über die tatsächliche Sicherheit von MFA-Systemen in der Praxis. Studien zur Awareness zeigen, dass ein mangelndes Verständnis für die Funktionsweise und Notwendigkeit der Anwendung häufig zu seltener Nutzung oder gar aktivem Umgehungsverhalten führt (Acemyan et al., 2018, S. 1141–1143). Eine summative Usability-Bewertung von Googles 2FA-Methoden ergab beispielsweise, dass trotz hoher kryptografischer Sicherheit erhebliche Usability-Probleme bestehen, welche die Akzeptanz massiv beeinträchtigen. Weitere Feldstudien beleuchten die Verbreitung und Wahrnehmung von FIDO-Technologien in konkreten Kontexten und liefern empirische Hinweise auf Adoptionsblockaden (Keil & Zugenmaier, 2024, S. 76–77).

Historische Betrachtungen des Übergangs zu verpflichtender 2FA in bestimmten Sektoren belegen, dass regulatorische Vorgaben und Compliance-Anforderungen als primäre

Treiber der Technologieverwendung fungieren. Die Einführung der starken Kundenauthentifizierung (SCA) durch die Zahlungsdiensterichtlinie PSD2 illustriert diesen regulatorischen Druck deutlich. Zugleich können derartige Vorgaben jedoch auch Usability-Probleme induzieren und innerbetriebliche Supportaufwände erhöhen. Eine vergleichende Studie verschiedener 2FA-Methoden zeigt, dass Nutzer:innen stets zwischen Sicherheit und Convenience abwägen und dabei Methoden bevorzugen, die den geringsten kognitiven und zeitlichen Aufwand erfordern (Reese et al., 2019, S. 360).

Spezifische Usability-Analysen zu Hardware-Security-Keys und FIDO-Tokens untersuchen Aspekte wie Setup-Komplexität, Fehlerquoten und subjektive Zufriedenheit. Die Ergebnisse deuten darauf hin, dass physische Keys zwar höchste Sicherheit garantieren, in Teilen der breiten Nutzerpopulation jedoch auf signifikante Akzeptanzhürden stoßen (Ciolino et al., 2019, S. 46).

Weitere empirische Arbeiten adressieren soziodemografische und kontextuelle Determinanten der Akzeptanz. Variablen wie Geschlecht oder Alter wurden in mehreren Studien untersucht (Gratian et al., 2018, S. 349–350), wobei die heterogenen Ergebnisse darauf hindeuten, dass die Akzeptanz stark individuell und kontextabhängig erklärbar ist. So identifizierten Pratama und Firmansyah (2021) Faktoren wie das individuelle Einkommen und das technische Selbstvertrauen als relevante Prädiktoren. Ebenso üben psychologische Faktoren, insbesondere die subjektive Risikowahrnehmung und IT-Awareness, einen signifikant positiven Einfluss auf die MFA-Adoptionsbereitschaft aus.

Ein entscheidender persönlicher Faktor ist zudem das jeweilige Domänenwissen. Eine Untersuchung der Implementierung von MFA in organisatorischen Kontexten identifiziert mangelnde Management-Unterstützung, unzureichende Schulungsangebote und eine fehlende Integration in bestehende Workflows als zentrale Barrieren (Das et al., 2021, S. 2–5). Ein Bereich, der selbst bei IT-Expert:innen häufig auf Skepsis stößt, ist die Biometrie. Während Laien biometrische Verfahren aufgrund ihrer inhärenten Bequemlichkeit oft bevorzugen, zeigen Sicherheitsexpert:innen Vorbehalte bezüglich des unwiderruflichen Diebstahls biometrischer Daten und nutzen diese Funktionen seltener. Ein bemerkenswertes abweichendes Verhalten bei Nicht-Expert:innen ist hingegen das „Co-Registrieren“ von Fingerabdrücken: Partner:innen speichern ihre biometrischen Merkmale gegenseitig auf ihren Geräten, um Convenience-Vorteile zu erzielen, was das Sicherheitskonzept untergräbt (Wolf et al., 2019, S. 4). Gleichzeitig belegen Studien, dass MFA-Technologien durchaus auch als wertvolles Zeichen von Sicherheit erlebt werden. So schätzten mehrere Teilnehmende einer Studie von Krol et al. (2015, S. 5) die sichtbare, zusätzliche Sicherheitsebene bei Banking-Anwendungen.

4.1.3 Einflussfaktoren mit Bezug zur IT-Governance

Die Literatur verdeutlicht übereinstimmend, dass die Einführung und Durchsetzung von Authentifizierungsmechanismen eine originäre Governance-Aufgabe darstellt. Governance um-

fasst in diesem Kontext die Domänen Awareness, Audit, Control, Compliance, Policy und Process, welche für die strategische Steuerung von IT-Sicherheitsprozessen innerhalb von Organisationen unerlässlich sind (Wibowo & Ramli, 2022, S. 6).

Etablierte IT-Governance-Frameworks wie die ISO 27001 oder die NIST Digital Identity Guidelines operationalisieren diese strategische Steuerung, indem sie notwendige Authenticator Assurance Levels (AAL) und verbindliche Anforderungen an die einzusetzenden Technologien definieren. Im öffentlichen Sektor rückt in diesem Zusammenhang die Frage nach digitaler Souveränität und einer verlässlichen Vertrauensinfrastruktur in den Vordergrund: Publikationen zur E-Government-Governance (vgl. Ariyadi & Akbar, 2025) betonen, dass eine nachhaltige digitale Transformation nur durch fundierte Policy-Frameworks gelingt. Diese müssen eine robuste IT-Infrastruktur, kontinuierliche Kapazitätsentwicklung sowie die Kollaboration zwischen Regierung, Privatsektor und Zivilgesellschaft orchestrieren (Ariyadi & Akbar, 2025, S. 154).

In Unternehmenskontexten manifestieren sich zusätzliche organisatorische Herausforderungen: Phänomene wie Vendor Lock-in, Cloud-Abhängigkeiten und Integrationsprobleme in bestehende IAM-Strukturen treten auf, da viele MFA-Lösungen als isolierte Silosysteme entwickelt werden und die Vertrauenswürdigkeit von Third-Party-Anbietern kontinuierlich evaluiert werden muss (Ometov et al., 2018, S. 10). Hinzu kommt ein oft erheblicher administrativer Helpdesk-Aufwand bei Tokenverlust oder vergessenen Credentials (Das et al., 2020, S. 5446; Temoshok et al., 2025, S. 47–50).

Eine der größten strukturellen Herausforderungen stellt die Entstehung informeller Umgehungssysteme dar. Diese sogenannte Schatten-IT (Shadow-IT) formiert sich häufig als direkte Reaktion auf zu strikte, prozesshemmende oder nutzer:innenunfreundliche Governance-Vorschriften (Fagan & Khan, 2016, S. 66–67).

Gleichzeitig verstärken aktuelle regulatorische Entwicklungen auf europäischer Ebene (wie die NIS-2-Richtlinie oder DORA) die Anforderungen an organisationale Nachweispflichten und das Risikomanagement kritischer Dienste massiv. Entsprechende Analysen zu diesen Direktiven sind für die zukunftssichere Ausgestaltung von MFA-Governance-Strategien zwingend heranzuziehen (Europäische Union, 2022a). Aus Governance-Sicht erfordert die erfolgreiche Implementierung von MFA folglich nicht nur technologische Expertise, sondern gleichermaßen klare Verantwortlichkeiten sowie kontinuierliche Awareness- und Schulungsprogramme für die Mitarbeitenden (de Bruijn et al., 2017, S. 2).

4.2 Wirkmechanismen der Nutzung von MFA

Die Synthese der betrachteten Literatur belegt, dass IT-Governance nicht isoliert an den Unternehmensgrenzen endet. Vielmehr kann sie – im Sinne eines Spill-over-Effekts – als maßgeblicher Katalysator für das private Sicherheitsverhalten der Mitarbeitenden fungieren. Konkret lassen sich aus dem Forschungsstand drei zentrale Wirkmechanismen extrahieren:

1. Kompetenz-Transfer: Die größte Hürde für die private MFA-Nutzung ist oftmals nicht der prinzipielle Widerwille gegen die Technologie, sondern die Unsicherheit in der korrekten Anwendung. Strenge Governance-Richtlinien im beruflichen Umfeld zwingen Nutzer:innen dazu, diese initiale Hürde zu überwinden. Studien (wie jene von Colnago et al., 2018, S. 15)

bestätigen diesen Lerneffekt: User:innen, die die Usability von MFA-Token im professionellen (und support-gestützten) Kontext des Unternehmens kennenlernen, trauen sich deren Anwendung in der Folge auch privat zu. Dieser Kompetenzaufbau reduziert signifikant die sogenannte *Recovery Anxiety* – die Angst vor dem dauerhaften Aussperren. Nutzer:innen befürchten häufig, unwiderruflich den Zugriff auf ihre Konten zu verlieren, falls der Hardware-Token oder das Smartphone verloren geht (Pratama & Firmansyah, 2021, S. 12). Die im beruflichen Kontext erworbene Routine hilft, diese Ängste im Privatleben abzubauen.

2. Differenzierte Risikowahrnehmung (Awareness): Während private Nutzer:innen Cyber-Risiken oft als abstrakt oder für sie persönlich irrelevant einschätzen (Optimismus-Bias), wird das Risikomanagement in Unternehmen greifbar operationalisiert. Wibowo und Ramli (2022) zeigten, wie unternehmerische Kontrollmechanismen User:innen dazu zwingen, sich aktiv mit Bedrohungsszenarien auseinanderzusetzen. Governance-Richtlinien (z. B. basierend auf NIS-2 oder der DSGVO) kommunizieren explizit, *warum* bestimmte Daten schützenswert sind. Diese gezielte Sensibilisierung transferiert sich in den privaten Alltag, wie Das et al. (2018) nachweisen konnten. Die beruflich gewonnene Awareness für Datenschutz und IT-Risiken beeinflusst somit proaktiv die freiwillige Nutzung von Sicherheitstechnologien im privaten Umfeld.

3. Reaktivität und persönlicher Widerstand: Im Gegensatz zu den positiven Transferleistungen dokumentiert die Literatur jedoch auch negative Auswirkungen (negativer Spill-over). Quellen wie Reuter et al. (2022) und Das et al. (2021, S. 15) belegen, dass eine zu starre IT-Governance in Verbindung mit schlechter Usability zu starker innerer Ablehnung führt. Empfinden Mitarbeitende die Sicherheitsvorgaben als reine Schikane oder massive Arbeitsbehinderung (Security Fatigue, siehe Grundlagen), resultiert dies nicht in einer privaten Adoption der Technologie. Vielmehr entsteht eine kognitive Abwehrhaltung, die dazu führt, dass diese Personen Sicherheitstechnologien im privaten Bereich aktiv vermeiden, um kognitive Entlastung zu suchen.

5 Forschungsmethodik

5.1 Forschungsdesign und wissenschaftstheoretische Einordnung

Die vorliegende Arbeit verwendet ein quantitatives Forschungsdesign, das deduktiv ausgerichtet ist. Gemäß diesem Ansatz kann wissenschaftlicher Fortschritt nur durch Falsifikation erzielt werden. Dementsprechend wurden aus der bestehenden Literatur (Usability-Forschung, IT-Governance, Spill-over-Theorie) theoriegeleitete Hypothesen abgeleitet, die empirisch überprüft werden, um die Nullhypothese (H_0) zu verwerfen. Für die Beantwortung der Forschungsfrage – inwiefern IT-Governance als Einflussfaktor auf die private Verwendung von Multifaktor-Authentifizierung (MFA) wirkt – ist ein quantitativer Ansatz zwingend erforderlich. Es gilt, die Stärke und Richtung der Zusammenhänge zwischen der beruflichen MFA-Nutzung, der wahrgenommenen Usability, den Governance-Vorgaben und dem privaten Sicherheitsverhalten zu messen. Während qualitative Methoden tiefere Einblicke in individuelle Motive bieten könnten, erlaubt erst die standardisierte quantitative Erhebung ge-

neralisierbare Aussagen über Kausalitäts-Tendenzen und signifikante Korrelationen in der breiten Masse der Erwerbstätigen. Der primäre Fokus der Untersuchung liegt dabei auf der Schnittstelle zwischen Arbeitswelt und Privatleben (Work-Life-Interface bzw. Security Spillover). Die methodische Bearbeitung dieser Arbeit folgt einem zweistufigen Forschungsdesign, bestehend aus einer systematischen Literaturrecherche und einer darauf aufbauenden, quantitativen Datenerhebung.

5.1.1 Systematische Literaturrecherche als theoretisches Fundament

Den ersten methodischen Schritt bildete eine umfassende Literaturrecherche. Dabei wurden aktuelle wissenschaftliche Publikationen, Fachbeiträge sowie internationale Standards und Regularien (wie beispielsweise die Richtlinien von NIST oder ISO) systematisch analysiert, um die technischen Spezifikationen der Multifaktor-Authentifizierung (MFA) mit etablierten IT-Governance-Faktoren in Verbindung zu setzen. Ziel dieser theoretischen Vorarbeit war es, die Nutzungsmuster im beruflichen und privaten Sektor gegenüberzustellen, kontextuelle Unterschiede herauszuarbeiten sowie zentrale Erfolgsfaktoren und Implementierungshindernisse zu identifizieren. Die Erkenntnisse dieser systematischen Recherche bilden das deduktive Fundament für die Konstruktion des Erhebungsinstruments der anschließenden empirischen Untersuchung.

5.1.2 Operationalisierung und theoriegeleitete Itemgenerierung

Die Konstruktion des Erhebungsinstruments (Fragebogen) stützt sich deduktiv auf die zentralen Erkenntnisse der vorangegangenen Literaturrecherche. Um eine hohe Inhaltsvalidität zu gewährleisten, wurden die in der Literatur identifizierten Hemmnisse und Treiber der MFA-Nutzung in messbare Indikatoren (Items) übersetzt. Die Items wurden dabei primär auf einer fünfstufigen Likert-Skala (1 = „stimme gar nicht zu“ bis 5 = „stimme voll zu“) formuliert.

5.2 Grundgesamtheit und Stichprobenziehung

Um die Validität der Ergebnisse zu gewährleisten, muss die Zielgruppe präzise eingegrenzt werden. Die Grundgesamtheit der vorliegenden Untersuchung bilden **erwerbstätige Personen im DACH-Raum, die im Rahmen ihrer beruflichen Tätigkeit regelmäßig mit IT-Systemen und digitalen Authentifizierungsverfahren konfrontiert sind**. Die Rekrutierung der Proband:innen erfolgt über eine Gelegenheitsstichprobe (Convenience Sampling). Die Distribution des Online-Fragebogens wird primär über berufliche Netzwerke (wie LinkedIn und Xing) sowie private Kommunikationskanäle durchgeführt. Diese Methode ermöglicht eine effiziente und breite Streuung. Im Rahmen der Erhebung wird streng auf die Einhaltung der Datenschutz-Grundverordnung (DSGVO) geachtet. Zu Beginn der Umfrage werden die Teilnehmenden über die Freiwilligkeit, den Zweck der Studie sowie die vollständig anonyme und aggregierte Speicherung der Daten aufgeklärt, was insbesondere bei dem sensiblen Thema IT-Sicherheit unabdingbar ist, um sozial erwünschtes Antwortverhalten zu minimieren. Die Primärdatenerhebung erfolgt mittels einer Online-Umfrage über das Tool *Microsoft*

Forms. Diese Methode bietet den Vorteil der Ortsunabhängigkeit, einer leichten Skalierbarkeit sowie einer effizienten digitalen Weiterverarbeitung der Daten. Der verwendete Fragebogen wurde anhand eines klaren dramaturgischen Aufbaus konzipiert: Nach der Einleitung und Klärung des Datenschutzes werden zunächst demografische Daten (Alter, Branche, IT-Affinität) erhoben. Anschließend folgen Fragen zum beruflichen Kontext (Governance-Vorgaben), zum privaten Status Quo der MFA-Nutzung sowie abschließend zur Usability-Bewertung. Die Formulierung der Items orientiert sich an den methodischen Vorgaben der empirischen Sozialforschung, insbesondere den „10 Geboten der Frageformulierung“ nach Porst (2014). Um Verzerrungen zu vermeiden, wird auf Suggestivfragen, doppelte Verneinungen sowie zu komplexe Satzstrukturen verzichtet. Die Erfassung der Einstellungen und Wahrnehmungen erfolgt primär über geschlossene Fragen sowie 5-stufige Likert-Skalen (von „stimme gar nicht zu“ bis „stimme voll zu“).

5.3 Methodisches Vorgehen und Instrumentenentwicklung

5.3.1 Operationalisierung und Itemgenerierung

Zur empirischen Überprüfung der aufgestellten Hypothesen wurden die theoretischen Konstrukte in messbare Fragebogenitems überführt (Operationalisierung). Die Generierung der Items basierte auf den Erkenntnissen der vorangegangenen Literaturrecherche. Um Einstellungen, Wahrnehmungen und Verhaltensweisen der Proband:innen präzise zu erfassen, wurde primär eine fünfstufige Likert-Skala (von 1 = „stimme gar nicht zu“ bis 5 = „stimme voll zu“) gewählt. Dieses Format gewährleistet annähernd gleiche Abstände zwischen den Intervallen und hat sich in der empirischen Einstellungsforschung bewährt (vgl. Rohrmann, 1978). Die Formulierung erfolgte in Frage- und Statementform nach den Richtlinien von Porst (2014), wobei suggestive oder doppelt verneinte Konstruktionen vermieden wurden. Um die theoretischen Konzepte messbar zu machen, wurden die Variablen wie folgt operationalisiert:

- **Abhängige Variable (Private MFA-Nutzung):** Gemessen über die Nutzungshäufigkeit und die Art der privat abgesicherten Dienste (z. B. Social Media, Banking, E-Mail).
- **Unabhängige Variable 1 (IT-Governance):** Gemessen über den wahrgenommenen Druck, die Verbindlichkeit von Richtlinien (Compliance) und die Unterstützung durch den Arbeitgeber (zur Überprüfung von H_1).
- **Unabhängige Variable 2 (Usability):** Gemessen über die wahrgenommene Einfachheit der Bedienung und die kognitive Last, in Anlehnung an etablierte Skalen wie die System Usability Scale (SUS) (zur Überprüfung von H_2).
- **Unabhängige Variable 3 (Spill-over-Effekt):** Erfasst durch Items, die eine psychologische Übertragung von beruflichen Gewohnheiten ins Privatleben abfragen (zur Überprüfung von H_3).

5.3.2 Aufbau des Online-Fragebogens

Der finale Online-Fragebogen (vgl. Anhang) gliedert sich in vier strukturierte Abschnitte, um die definierten Variablen systematisch zu erheben:

1. **Filterfrage und Demografie:** Eine obligatorische Filterfrage stellt sicher, dass die Teilnehmenden zur Grundgesamtheit gehören (berufstätig mit IT-Nutzung). Anschließend werden Kontrollvariablen wie Alter und subjektive IT-Affinität erhoben.

2. **Beruflicher Kontext (IT-Governance):** Erhebung der MFA-Pflicht am Arbeitsplatz, der eingesetzten Methoden sowie Bewertung der Transparenz und Strenge der IT-Sicherheitsrichtlinien.

3. **Privater Kontext und Spill-over-Effekt:** Erfassung des Status Quo der privaten MFA-Nutzung sowie Messung des kompetenzbasierten und psychologischen Übertrags (Spill-over) in das Privatleben.

5.3.3 Pre-Test und Datenerhebung

Vor der eigentlichen Feldphase wurde der Entwurf des Fragebogens einem Pre-Test mit einer kleinen Stichprobe ($n = 5$) unterzogen. Ziel war es, die technische Funktionalität (z. B. korrekte Filterführung, mobile Darstellung), die Bearbeitungsdauer (ca. fünf Minuten) sowie die semantische Verständlichkeit zu prüfen. Basierend auf dem Feedback wurden leichte sprachliche Präzisierungen bei den Fragen zur privaten MFA-Nutzung vorgenommen, um die Validität des Messinstruments zu sichern. Die finale Datenerhebung erfolgte mittels des standardisierten Online-Fragebogens über einen Zeitraum von drei Wochen (KW 13–15 2026), um eine möglichst breite und heterogene Stichprobe zu erreichen. Insgesamt konnten 150 vollständige Datensätze erhoben werden, die in die anschließende statistische Analyse einbezogen werden.

5.4 Datenaufbereitung und Auswertungsverfahren

Die Datenanalyse erfolgt mit der Open-Source-Software *Orange Data Mining*. Die Wahl fiel auf dieses Tool, da es durch seine visuelle Programmierung eine transparente und nachvollziehbare Kombination aus Datenaufbereitung, Datenanalyse und inferenzstatistischer Testung innerhalb einer Workflow-Umgebung ermöglicht. Der gesamte Analyseprozess wurde als Orange-Workflow (`.ows`) dokumentiert. Über das *File Widget* werden die Rohdaten aus den Befragungen importiert. Im Rahmen der Datenvorverarbeitung werden unvollständige Datensätze ausgeschlossen (*Data Cleaning*). Über die *Feature Selection* und *Edit Domain* werden die Variablentypen definiert (Ordinal für Likert-Skalen, Nominell für demografische Merkmale). Zudem werden Ausreißer (z. B. „Speed-Speeder“ mit unrealistisch kurzen Bearbeitungszeiten) herausgefiltert. Die deskriptive Statistik dient zur Darstellung der Stichprobenverteilung. Mittels des *Distributions Widgets* (Histogramme) werden soziodemografische

Daten und allgemeine MFA-Nutzungshäufigkeiten visualisiert. *Box Plots* kommen zum Einsatz, um Unterschiede in der Usability-Bewertung zwischen verschiedenen Nutzergruppen (z. B. hohe vs. niedrige IT-Affinität) visuell zu prüfen.

6 Zusammenfassung

Die vorliegende Arbeit hat gezeigt, dass die technische Sicherheit von Multifaktor-Authentifizierung allein nicht ausreicht, um eine flächendeckende Nutzung zu gewährleisten. Vielmehr hängt ihre Wirksamkeit maßgeblich von der Benutzbarkeit und der Akzeptanz der Anwender:innen ab. Wie die Literaturanalyse verdeutlichte, wird MFA von Nutzer:innen häufig als Störfaktor im Arbeitsfluss oder als zeitraubend wahrgenommen. Insbesondere im privaten Kontext, wo Nutzer:innen bei technischen Problemen auf sich allein gestellt sind, Risiken nur diffus wahrnehmen, und kein institutioneller Druck besteht, führt diese wahrgenommene Hürde oft zur Umgehung von Sicherheitsmechanismen. In diesem Spannungsfeld tritt IT-Governance als entscheidende Treiberin auf. Im beruflichen Umfeld ersetzt sie die oft fehlende intrinsische Motivation durch regulatorische Notwendigkeit. In der Literaturbetrachtung zeigt sich, dass Governance hier eine Doppelfunktion erfüllt: Einerseits erzwingt sie die Nutzung durch Richtlinien und technische Kontrollen. Andererseits unterstützt sie diesen Zwang durch Support-Strukturen (zum Beispiel Helpdesk, Schulung). Diese senken die Hürden bei der Einrichtung und erleichtern die Fehlerbehebung, und sind im privaten Kontext meistens nicht vorhanden. Ein zentrales Ergebnis dieser Arbeit ist die Beschreibung des sogenannten „Spill-over-Effekts“ als Bindeglied zwischen beruflichen und privaten Kontexten. Die betrachteten Forschungsdokumente legen nahe, dass die verpflichtende Nutzung in beruflichen Kontexten auch die Akzeptanz im privaten Kontext fördern kann. Indem Nutzer:innen im geschützten Unternehmensumfeld Kompetenzen aufbauen und die Verwendung von Technologie normalisieren, sinkt die Hemmschwelle, diese auch privat einzusetzen. Die zentrale Forschungsfrage, wie IT-Governance die Verwendung von MFA beeinflusst, lässt sich somit beantworten: IT-Governance wirkt als Katalysator sowohl durch Supportmaßnahme wie zur Sensibilisierung. Indem Governance im Beruf technische Standards durchsetzt und dafür sensibilisiert, wirkt sie auch in anderen Kontexten, also über Unternehmensgrenzen hinaus und leistet indirekt einen Beitrag zur Erhöhung der privaten Sicherheitskompetenz der Mitarbeitenden.

7 Zusammenfassung

Die vorliegende Arbeit hat gezeigt, dass die technische Sicherheit von Multifaktor-Authentifizierung allein nicht ausreicht, um eine flächendeckende Nutzung zu gewährleisten. Vielmehr hängt ihre Wirksamkeit maßgeblich von der Benutzbarkeit und der Akzeptanz der Anwender:innen ab. Wie die Literaturanalyse verdeutlichte, wird MFA von Nutzer:innen häufig als Störfaktor im Arbeitsfluss oder als zeitraubend wahrgenommen. Insbesondere im privaten Kontext, wo Nutzer:innen bei technischen Problemen auf sich allein gestellt sind, Risiken nur diffus wahrnehmen, und kein institutioneller Druck besteht, führt diese wahrgenommene Hürde oft zur

Umgehung von Sicherheitsmechanismen. In diesem Spannungsfeld tritt IT-Governance als entscheidende Treiberin auf. Im beruflichen Umfeld ersetzt sie die oft fehlende intrinsische Motivation durch regulatorische Notwendigkeit. In der Literaturbetrachtung zeigt sich, dass Governance hier eine Doppelfunktion erfüllt: Einerseits erzwingt sie die Nutzung durch Richtlinien und technische Kontrollen. Andererseits unterstützt sie diesen Zwang durch Support-Strukturen (zum Beispiel Helpdesk, Schulung). Diese senken die Hürden bei der Einrichtung und erleichtern die Fehlerbehebung, und sind im privaten Kontext meistens nicht vorhanden. Ein zentrales Ergebnis dieser Arbeit ist die Beschreibung des sogenannten „Spill-over-Effekts“ als Bindeglied zwischen beruflichen und privaten Kontexten. Die betrachteten Forschungsdokumente legen nahe, dass die verpflichtende Nutzung in beruflichen Kontexten auch die Akzeptanz im privaten Kontext fördern kann. Indem Nutzer:innen im geschützten Unternehmensumfeld Kompetenzen aufbauen und die Verwendung von Technologie normalisieren, sinkt die Hemmschwelle, diese auch privat einzusetzen. Die zentrale Forschungsfrage, wie IT-Governance die Verwendung von MFA beeinflusst, lässt sich somit beantworten: IT-Governance wirkt als Katalysator sowohl durch Supportmaßnahme wie zur Sensibilisierung. Indem Governance im Beruf technische Standards durchsetzt und dafür sensibilisiert, wirkt sie auch in anderen Kontexten, also über Unternehmensgrenzen hinaus und leistet indirekt einen Beitrag zur Erhöhung der privaten Sicherheitskompetenz der Mitarbeitenden.

8 Anhang